

AVALIA SOLAR 2026

Relatório de Auditoria de Segurança

Cinco categorias: isolamento, autorização, IDOR, segredos e XSS

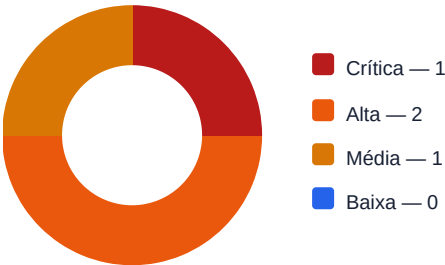
Data: 30/08/2026

Escopo: monorepo completo: Rails API, Next.js, Expo, Docker, CI e configurações.

Metodologia: categorias mapeadas para Rails + ActiveRecord + JWT/Devise/Pundit, Next.js/React, Expo e artefatos de infraestrutura. Foram reportados somente sinks e fluxos verificados no código versionado; hipóteses sem rota ou evidência foram excluídas.

Resumo executivo

Avalia Solar 2026 · Auditoria de Segurança · página



Achados por categoria



Pontos fortes

- ✓ Mecanismo de isolamento identificado: filtros manuais por empresa/associação, memberships ativas e Pundit; vários controllers usam escopos aninhados.
- ✓ Usuários: show/update/destroy têm autenticação e bloqueio para o próprio usuário ou admin (users_controller.rb:3-5, 119-131).
- ✓ Lead distributions: autenticação e autorização por company/membership (lead_distributions_controller.rb:2-4, 42-49).
- ✓ Intent scores: autenticação, empresa derivada do score e Pundit/feature gate antes da resposta (intent_scores_controller.rb:6-9, 80-90).

Pontos fracos centrais

Segredo criptográfico versionado, defaults de banco permissivos, status de proposta sem posse e JSON-LD raw em contexto HTML.

Achados detalhados

Avalia Solar 2026 · Auditoria de Segurança · página

Severidade	Arquivo:linha	Descrição e evidência
crítica	AB0-1-back/config/credentials.yml:9	Chaves expostas secret_key_base está versionado em texto claro. O valor protege MessageVerifiers e cookies Rails; qualquer leitor do repositório pode forjar tokens/cookies assinados. <pre>secret_key_base: [REDACTED]</pre> Impacto: Comprometimento de sessões e dados protegidos. Correção: Revogar/rotacionar imediatamente; remover do histórico; usar Rails credentials cifradas ou secret manager; bloquear startup sem segredo de produção.
alta	AB0-1-back/config/database.yml:28-30	Chaves expostas Configuração de produção aceita host, usuário e senha padrão quando variáveis estão ausentes, incluindo password. <pre>password: <%= ENV.fetch("POSTGRES_PASSWORD") { "password" } %></pre> Impacto: Deploy mal configurado pode conectar com credencial previsível. Correção: Usar ENV.fetch sem fallback em produção e falhar no boot; validar POSTGRES_PASSWORD e demais segredos.
alta	AB0-1-back/app/controllers/api/v1/financing_proposals_controller.rb:91-95	IDOR status busca Lead apenas por params[:id], sem autenticação, posse ou conferência com company_id. <pre>lead = ::Lead.find(params[:id])</pre> Impacto: Qualquer cliente que conheça um ID pode consultar status de proposta de outro cliente. Correção: Exigir autenticação apropriada e buscar por company/owner; usar escopo autorizado e identificador não enumerável.
média	AB0-1-front/app/companies/[id]/categories/[categorySlug]/page.tsx:114-117; AB0-1-front/app/companies/CompaniesPageClient.tsx:654-659; AB0-1-front/app/melhores-empresas/[category_slug]/[state]/[city]/page.tsx:150-153	XSS JSON.stringify de dados que podem conter conteúdo persistido é inserido diretamente em script via dangerouslySetInnerHTML. JSON não escapa para contexto HTML. <pre>dangerouslySetInnerHTML={{ __html: JSON.stringify(itemList) }}</pre> Impacto: Conteúdo armazenado com fechamento de script pode injetar markup/script na página. Correção: Serializar para contexto HTML seguro, escapando <, >, &, ou usar utilitário de JSON-LD seguro; validar campos e CSP como defesa secundária.

Recomendações priorizadas

Avalia Solar 2026 · Auditoria de Segurança · página

1. **P1:** rotacionar `secret_key_base` e revisar histórico Git; bloquear boot de produção sem segredos.
2. **P1:** proteger status de propostas por autenticação e escopo de proprietário/empresa.
3. **P2:** substituir defaults de `database.yml` por validação obrigatória no ambiente de produção.
4. **P2:** trocar inserções JSON-LD por serialização HTML-safe.
5. **P3:** adicionar testes de autorização/IDOR para todos os recursos sensíveis e rodar Gitleaks no histórico.

Cobertura e itens corretos

Foram enumerados os controllers REST em `AB0-1-back/app/controllers/api/v1`, `policies`, rotas, queries por ID, frontend Next.js, mobile Expo, Docker, CI e configurações. Controllers de `dashboard/company-admin` geralmente combinam `authenticate_api_user`, empresa ativa e Pundit. O controller de fórum analisado não está registrado em `routes.rb`, portanto não foi reportado como endpoint explorável.

ISSUES PARA O GITHUB

Avalia Solar 2026 · Auditoria de Segurança · página

Textos completos, prontos para copiar e colar.

```
--- ISSUE 1 ---
# [Segurança] secret_key_base está versionado em texto claro

Labels sugeridas: security, crítica

## Descrição
secret_key_base está versionado em texto claro. O valor protege MessageVerifiers e cookies Rails; qualquer leitor do repositório
pode forjar tokens/cookies assinados.

## Evidência
`AB0-1-back/config/credentials.yml:9`
...
secret_key_base: [REDACTED]
...

## Impacto
Comprometimento de sessões e dados protegidos.

## Sugestão de correção
Revogar/rotacionar imediatamente; remover do histórico; usar Rails credentials cifradas ou secret manager; bloquear startup sem
segredo de produção.

## Critérios de aceite
- [ ] Segredo/objeto só pode ser acessado por chamador autorizado.
- [ ] Teste automatizado cobre tentativa não autorizada.
- [ ] Nenhum segredo permanece no código ou histórico.
- [ ] Logs e respostas não expõem dados sensíveis.

--- FIM ISSUE 1 ---
```

```
--- ISSUE 2 ---
# [Segurança] Configuração de produção aceita host, usuário e senha padrão quando variáveis estão ausentes, incluindo password

Labels sugeridas: security, alta

## Descrição
Configuração de produção aceita host, usuário e senha padrão quando variáveis estão ausentes, incluindo password.

## Evidência
`AB0-1-back/config/database.yml:28-30`
...
password: <%= ENV.fetch("POSTGRES_PASSWORD") { "password" } %>
...

## Impacto
Deploy mal configurado pode conectar com credencial previsível.

## Sugestão de correção
Usar ENV.fetch sem fallback em produção e falhar no boot; validar POSTGRES_PASSWORD e demais segredos.

## Critérios de aceite
- [ ] Segredo/objeto só pode ser acessado por chamador autorizado.
- [ ] Teste automatizado cobre tentativa não autorizada.
- [ ] Nenhum segredo permanece no código ou histórico.
- [ ] Logs e respostas não expõem dados sensíveis.

--- FIM ISSUE 2 ---
```

```
--- ISSUE 3 ---
# [Segurança] status busca Lead apenas por params[:id], sem autenticação, posse ou conferência com company_id
Avalia Solar 2026 · Auditoria de Segurança · página

Labels sugeridas: security, alta

## Descrição
status busca Lead apenas por params[:id], sem autenticação, posse ou conferência com company_id.

## Evidência
`AB0-1-back/app/controllers/api/v1/financing_proposals_controller.rb:91-95`
...

lead = ::Lead.find(params[:id])
...

## Impacto
Qualquer cliente que conheça um ID pode consultar status de proposta de outro cliente.

## Sugestão de correção
Exigir autenticação apropriada e buscar por company/owner; usar escopo autorizado e identificador não enumerável.

## Critérios de aceite
- [ ] Segredo/objeto só pode ser acessado por chamador autorizado.
- [ ] Teste automatizado cobre tentativa não autorizada.
- [ ] Nenhum segredo permanece no código ou histórico.
- [ ] Logs e respostas não expõem dados sensíveis.

--- FIM ISSUE 3 ---
```

```
--- ISSUE 4 ---
# [Segurança] JSON

Labels sugeridas: security, média

## Descrição
JSON.stringify de dados que podem conter conteúdo persistido é inserido diretamente em script via dangerouslySetInnerHTML. JSON não escapa </script> para contexto HTML.

## Evidência
`AB0-1-front/app/companies/[id]/categories/[categorySlug]/page.tsx:114-117; AB0-1-front/app/companies/CompaniesPageClient.tsx:654-659; AB0-1-front/app/melhores-empresas/[category_slug]/[state]/[city]/page.tsx:150-153`
...

dangerouslySetInnerHTML={{ __html: JSON.stringify(itemList) }}
...

## Impacto
Conteúdo armazenado com fechamento de script pode injetar markup/script na página.

## Sugestão de correção
Serializar para contexto HTML seguro, escapando <, >, &, ou usar utilitário de JSON-LD seguro; validar campos e CSP como defesa secundária.

## Critérios de aceite
- [ ] Segredo/objeto só pode ser acessado por chamador autorizado.
- [ ] Teste automatizado cobre tentativa não autorizada.
- [ ] Nenhum segredo permanece no código ou histórico.
- [ ] Logs e respostas não expõem dados sensíveis.

--- FIM ISSUE 4 ---
```